



Security audit — Site Log system

Sri Charan Constructions · 16-point check · 10 October 2026

Every result below comes from a test or inspection run against the actual code. Where the answer depends on your live Render or Supabase settings, which I cannot see, it is marked **ACTION** and listed on the last page.

#	Check	Result	What was verified	What you need to do
1	Login protection	PARTLY	10 guesses per 15 minutes per address, then blocked — even the correct PIN is refused while blocked. Every wrong PIN gets the identical answer. Odd input (numbers, lists, SQL text, a 20,000-character PIN) is handled cleanly. Failed and blocked logins are logged with IP and device, never with the PIN. New: obvious PINs (1234, 0000, 4321...) are refused when set.	Open risk: login uses a PIN only (no name) and PINs may be 4 characters, so one guess is tested against every user and a 4-digit PIN has only 10,000 possibilities (about 960 guesses a day from one address). Decide: require 6+ characters for new PINs.
2	Signup & verification	N/A	There is no public signup: only an Admin can create users, and /register, /signup return 404. There is no email or phone verification because there are no self-service accounts.	None. (Turn on 2-step sign-in for the GitHub, Render and Supabase accounts themselves — see Actions.)
3	Session security	PASS	Tokens are HS256 only and last 12 hours. Refused: alg "none", a different algorithm, a wrong secret, an expired token, a token whose role was edited, a deleted user. Deactivating a user or changing their role takes effect on the very next request. Tokens are accepted only in the Authorization header — never in the address or a cookie, so another site cannot ride on a login.	Residual: logging out does not cancel a stolen token for up to 12 hours (tokens are stateless). Optional: shorter life or automatic logout when idle.
4	Error message security	FIXED	15 places used to send raw database error text to the browser. All now send a generic message and keep the detail in the server log. A sweep of 41 different error answers found no stack trace, file path, table or library name. A bad token never says why.	None.
5	Password (PIN) reset	PASS	There is no "forgot PIN" page or API to attack. Only an Admin can reset a PIN (supervisor and owner get 403). The reset is logged as "PIN: Reset" without the PIN, and the old PIN stops working at once.	If the only Admin forgets their PIN, recovery is done in Supabase (explained earlier).
6	Backend & API security	PASS	Headers present: nosniff, no framing, no-referrer, HSTS, same-origin resources, Permissions-Policy, no X-Powered-By. New: Content-Security-Policy (scripts from this site only, no eval, calls only to this site, images only from this site and Supabase). Extra fields such as id, role or deleted_at in a request are ignored. Injection text in search boxes is harmless. Server code, .env, .git and node_modules cannot be fetched. Rate limits: login 10/15 min, API 300/15 min, photo uploads 60/15 min; reports 2 at a time.	Weakness kept on purpose: the policy allows inline scripts because the pages use inline buttons. All user text is escaped, but removing inline scripts would be the next hardening step.
7	Logging & monitoring	PASS	Logins, failures, blocks, logouts, refused requests ("Access denied") , user / inventory / entry changes, PIN resets and every report download are recorded. No PIN, token or file path ever appears in a log. A log row cannot be edited; only an Admin can delete, and every clean-up leaves a permanent "Logs deleted" record that cannot itself be deleted.	Nobody is alerted automatically. Suggestion: look at Activity Logs weekly, filtered for failed logins and access denied.
8	Secure database	ACTION	The browser never talks to the database. Photos are in a private bucket and open only through 10-minute links. Queries are parameterised, so SQL injection is not possible. New: a SQL file turns on Row Level Security for every table and removes the public roles' rights.	I cannot see your live Supabase. Run run-in-supabase-2-database-security.sql only after checking the key (see Actions), then run its two check queries. The free plan has no automatic backups (Pro does).

#	Check	Result	What was verified	What you need to do
9	Protect admin routes	PASS	34 endpoints were each tried with no login, a supervisor, an owner and an admin: all 136 combinations behave exactly as intended. Hidden screens are not the protection — the server refuses the call itself.	None.
10	Environment variables	FIXED	The 14 variables the code reads were listed. The server refuses to start without JWT_SECRET or SUPABASE_URL, and refuses a placeholder secret in production; it warns loudly about a short secret or a public key; it never prints a secret (10 start-up checks). Fixed: .env.example and README mentioned an unused public key.	On Render: confirm JWT_SECRET is 64+ characters and remove SUPABASE_ANON_KEY if it is set.
11	Hide API keys	PASS	None of the 11 files sent to the browser holds a key or secret; the browser code never contacts the database. The key is read in one place only. Your entire GitHub history (7 commits) was scanned: no .env file was ever committed and no real key is present.	None. (Rotate keys only if one was ever pasted somewhere public.)
12	Access control	PASS	Roles are enforced on the server. Supervisors can add entries and upload photos but cannot read records or open photos. Owners can read and export but not change anything. You cannot delete, demote or deactivate your own account. A deleted user cannot log in and their PIN is destroyed.	None.
13	CORS settings	FIXED	Before: the server told every website it was allowed to read API answers. Now no cross-site permission is sent at all, and a hostile website cannot read any answer (6 tests, including preflight and error responses). ALLOWED_ORIGIN is an opt-in for exact addresses.	None.
14	Remove unused packages	PASS	All 11 packages are used (the scan flagged ExcelJS, PDFKit and sharp, but they load on demand — verified). nodemon is development-only. The removed Manual Summary route file was deleted. npm audit on the live packages: 2 moderate, in a library ExcelJS uses; the flaw needs a feature ExcelJS does not use, and the automatic “fix” would downgrade ExcelJS and break reports, so it is left.	Delete backend/routes/summaries.js from your repository (it is no longer used).
15	Hash passwords	PASS	PINs are stored as salted bcrypt hashes; hashing the same PIN twice gives different results. An old plain-text PIN is converted to a hash the first time its owner logs in. No PIN or hash appears in any answer or log.	Run the check query in the security SQL: plain_text_pins should be 0.
16	Full security audit	PARTLY	698 backend checks, 453 browser checks, 25 install checks and 10 start-up checks all pass. Items 1, 8, 10 and 14 need something from you; everything else is verified.	See the Actions list on the last page.

PASS verified, nothing to do · **FIXED** a problem was found and corrected · **PARTLY** sound, with a decision or residual risk · **ACTION** needs a step from you · **N/A** does not apply by design

Actions for you

1	Decide the PIN rule. Recommended: at least 6 characters for every new or reset PIN. Existing PINs keep working until they are changed.
2	Check two values on Render (Environment). JWT_SECRET should be 64+ characters; SUPABASE_SERVICE_KEY must be the secret “service_role” key. Delete SUPABASE_ANON_KEY if it is there. The start-up log warns if either looks wrong.
3	Run the two SQL files in Supabase, in order. (1) run-in-supabase-1-user-tracking.sql (2) run-in-supabase-2-database-security.sql — only after step 2 shows no key warning. Then run the two check queries at the bottom of file 2 and tell me the results.
4	Switch on 2-step sign-in on the accounts themselves. GitHub, Render, Supabase and Google Play. A strong app does not help if someone takes over the hosting account.
5	Delete the unused file. backend/routes/summaries.js (git rm backend/routes/summaries.js).
6	Optional but wise. Review Activity Logs weekly (failed logins, access denied) · consider Supabase Pro for automatic backups · ask me for automatic logout when idle.

Not verifiable from here: the live values on Render, the live Row Level Security state and plain-text-PIN count in Supabase, and the security of your hosting accounts. Results come from automated tests against the code, not from a penetration test by an outside specialist.